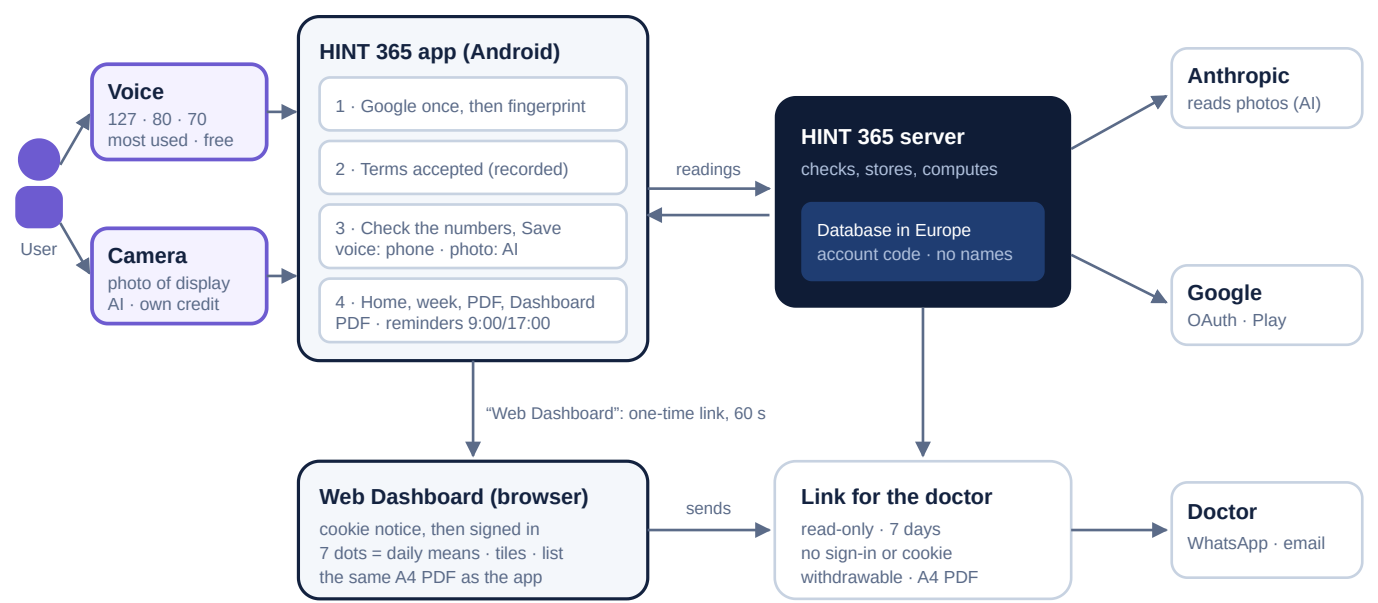


Functional overview

What the app does, who does what and in which order. A blood-pressure diary for Android, with a web dashboard and reports for the doctor.

The flow from the phone to the doctor



The user's path

1. **Installs** the app from the public link `/download` (later from Google Play).
2. **Signs in with Google** once, through OAuth 2.0 / OpenID Connect (a signed ID token, never the password), and gives privacy consent.
3. **Accepts the terms of use**, binding, at the first installation and after every update: without acceptance the app does not open. Every acceptance is recorded (pseudonymous account code, phone, versions, text fingerprint, date).
4. **Every day** unlocks with the phone's fingerprint or PIN, and stays signed in until "Sign out".
5. **Imports lab reports** by itself: PDF or photo read on the phone, every test (also outside the catalog), one report date; any doubt: nothing saved; never twice.
6. **Records** a reading: by voice (**SYS**, **DIA**, **PUL**, checked and confirmed on screen) or by photographing the display (AI features).
7. **Looks back**: last reading, the week; the Dashboard icon opens the Web Dashboard (Blood pressure first: chart, eight tiles, morning/evening balance, pulse; then Lab results).
8. **Shares**: PDF or Excel from the phone, or Web Dashboard → "Send to the doctor".
9. **Changes phone**: signs in with Google and finds everything. **Signs out or deletes the account** at any time.

Costs and who is paid

What	Cost	Paid to
HINT 365: app, charts, reports, Web Dashboard, keeping the readings	5 \$ a year, cancel any time	The app's owner, through Google Play
AI features, optional: Scan of the monitor (available now); anonymous medical documents (coming)	Pay-per-use, ≈ 0.006 \$ a photo	Anthropic, from the user's own credit

One app; the AI features are on or off (never "Premium"). The Anthropic credit is the user's own.

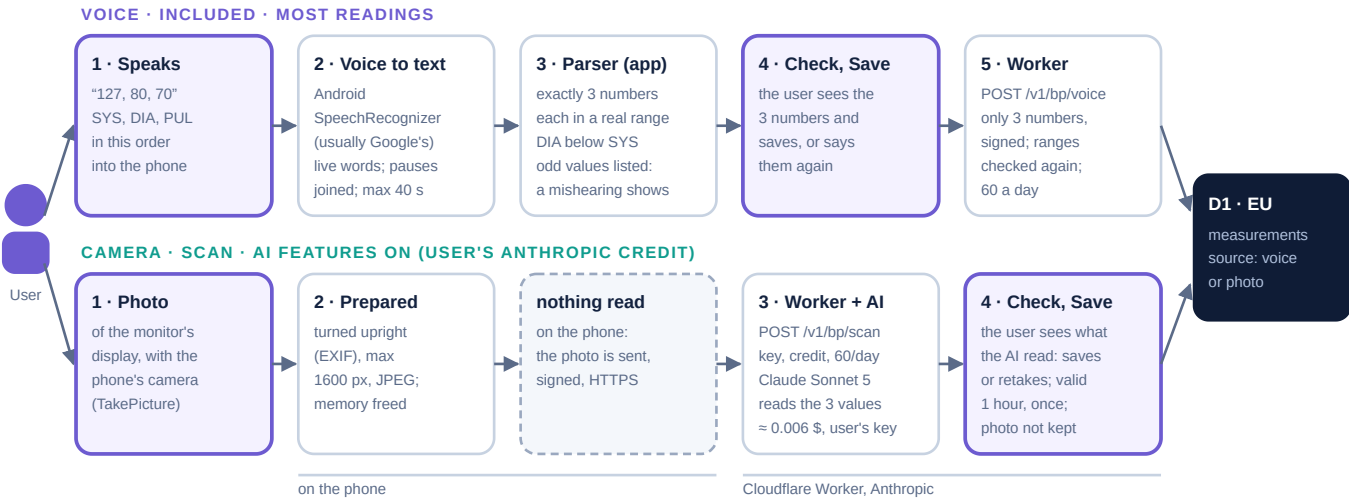
Fixed rules

- No diagnosis, no advice, no judgement of the values: no coloured zones, no "normal".
- Labels always **SYS**, **DIA**, **PUL**. Pressure and pulse never in the same chart.
- Charts: 7 days, one dot per day = the mean of that day's readings (explained before the charts), value next to it, axis with day numbers only. Tables show AM/PM.
- The same A4 PDF from the app and from the web.
- No red anywhere: **SYS** violet, **DIA** teal, **PUL** amber. No colour means "good" or "bad".
- Scan is on only when Anthropic has just confirmed key and credit (checked hourly on opening, after errors, on pull-down).
- Readings kept at most 365 days, deleted nightly; acceptances stay as proof.
- The app stays simple: the owner's controls are only in the web Admin area.

Input: voice, camera and local documents

How a reading enters HINT 365. Voice is the way most readings arrive; the camera (Scan) is the AI feature. Same result, different technology.

From the user to the database the input always starts on the user's side



Purple frame: a step done by the user. Voice: the numbers are recognised on the phone and only the three numbers travel. Camera: the photo travels to the Worker and to Anthropic, and is not kept.

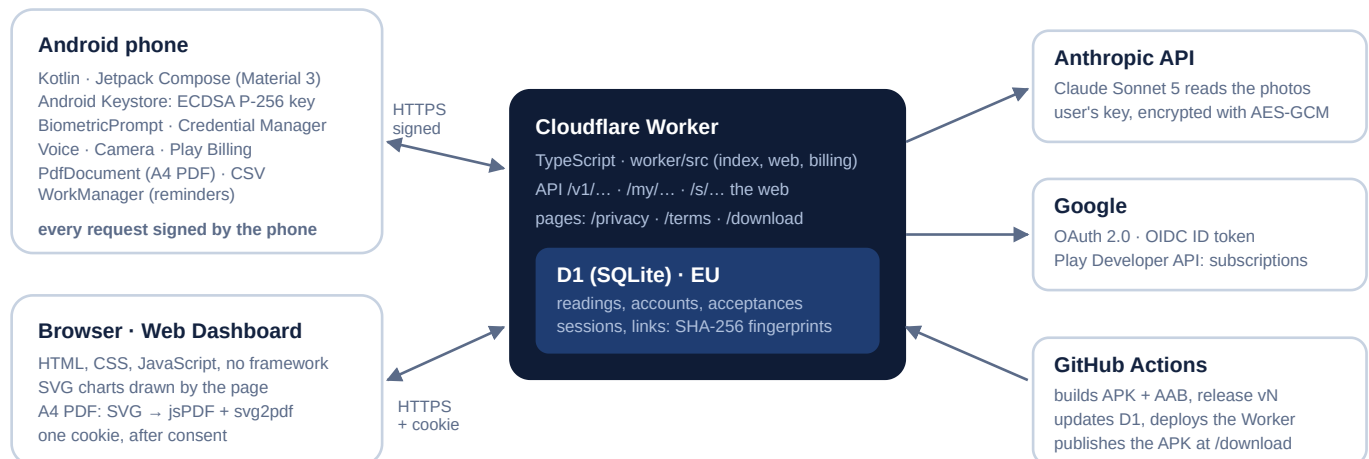
The differences

	Voice	Camera (Scan)
Who can use it	everyone, included in the app	only with the AI features on: the user's own Anthropic key and credit
What the user does	says the three numbers	photographs the monitor's display
Where the numbers are recognised	on the phone: Android speech recognition (usually Google's service), then HINT 365's own parser (<code>parseSpoken</code>)	on the server side: the Worker sends the image to Anthropic, Claude Sonnet 5 (vision) returns the three values
What leaves the phone	only the three numbers (the sound goes only to the phone's speech service)	the photo, reduced; deleted after reading, never stored
Cost	none	≈ 0.006 \$ a photo, from the user's Anthropic credit
Checks	exactly 3 numbers; SYS 50–260, DIA 30–160, PUL 30–220; DIA below SYS; odd values listed; user confirms; ranges again on the server	display readable; user confirms; the values read stay on the server 1 hour and can be saved once
Typical errors	a misheard number, noise, numbers said in the wrong order	glare, a blurred or cut display, an unusual monitor layout
Limits	60 a day	60 a day, and only while Anthropic confirms key and credit
Stored as	<code>measurements</code> , source <code>voice</code>	<code>measurements</code> , source <code>photo</code> ; a <code>scans</code> row with the cost
Code	<code>Listen.kt</code> , <code>Core.kt</code> (<code>parseSpoken</code>), <code>POST /v1/bp/voice</code>	<code>MainActivity.kt</code> (camera), <code>Core.kt</code> (<code>Img</code>), <code>POST /v1/bp/scan</code> , <code>/v1/bp/confirm</code>

Both ways end on the same check screen and in the same table: charts, reports and the doctor's link do not depend on how a reading came in. Neither judges the values.

Architecture and technology

The components, how they talk, where the data live and how a new version is released.



Components

Part	Technology	Folder
Android app	Kotlin, Compose, minSdk 26, target 34	android/
Server	Cloudflare Workers, TypeScript	worker/src/
Database	Cloudflare D1 (SQLite), EU jurisdiction	worker/schema.sql
Web dashboard	HTML/JS, own SVG charts, jsPDF + svg2pdf	worker/public/my/
Photo reading	Anthropic Messages API	index.ts
Sign-in	Sign in with Google (OAuth 2.0 / OpenID Connect) + phone key	Google.kt
Subscription	Google Play Billing + Play Developer API	Billing.kt , billing.ts
Build, release	GitHub Actions, Gradle, Wrangler	.github/workflows/
Guides, documents	HTML → PDF (Playwright)	docs/

Database tables

persons accounts (pseudonymous account code, Google fingerprint, no email; subscription sub_*) · measurements pressure + lab results · lab_files keyed file fingerprints (no duplicates) · scans photo readings · ledger credit and costs · person_keys encrypted Anthropic keys · acceptances accepted terms (versioned evidence) · web_* web access and doctor links · settings, invites · error_log, event_log (import outcomes, codes only) · seen_sigs, rate_limits protection counters; security_snapshot_findings completed scan snapshots.

Security and data

- Phone:** a private key that never leaves the phone signs every request; bad signatures, clocks off by over 5 min and replayed canonical messages are refused; mandatory Google nonce, single-use token and browser revocation on recovery.
- Limits:** hourly/daily caps on sign-ups, sign-ins, links, logs, Scan, voice (rate_limits, IP only as SHA-256). CSP and anti-framing headers; robots.txt.
- Web:** a 60 s atomically redeemed code in the # part of the address becomes the only cookie, hint_s (technical, 7 days, HttpOnly, Secure, SameSite=Strict), set only after consent. The app uses no cookies.
- Doctor links:** read-only, fixed period, expire after 7 days, withdrawable; no sign-in or cookie.
- Remote switch-off:** the app version travels with every request; settings holds app_min_version, app_blocked, app_off. Owner only, from the web Admin area.
- Owner's area** (web, owner only): totals only (users, AI on/off, readings by voice/Scan, AI spent, errors), D1 size vs the 500 MB free limit. Never values, codes or names.
- Subscription** (ready, off until Google Play): Play Billing, checked with the Play Developer API.
- Retention:** readings older than 365 days deleted every night; acceptances in an acceptance register.
- Personal data:** no name, no email (Google account only as HMAC-SHA256); codes, cookies, links only as SHA-256; Anthropic keys AES-GCM; documents read on-device; only lab results and a keyed file fingerprint sync. Source files never uploaded. Cloudflare D1 is EU-bound.

Releasing a version

- Change on a branch → pull request → merge into main.
- GitHub Actions updates D1, deploys the Worker, builds the APK and the AAB, stores APK/AAB in GitHub release v0.1.N; /download redirects there.
- The site changes at once; the app updates by installing the new APK.

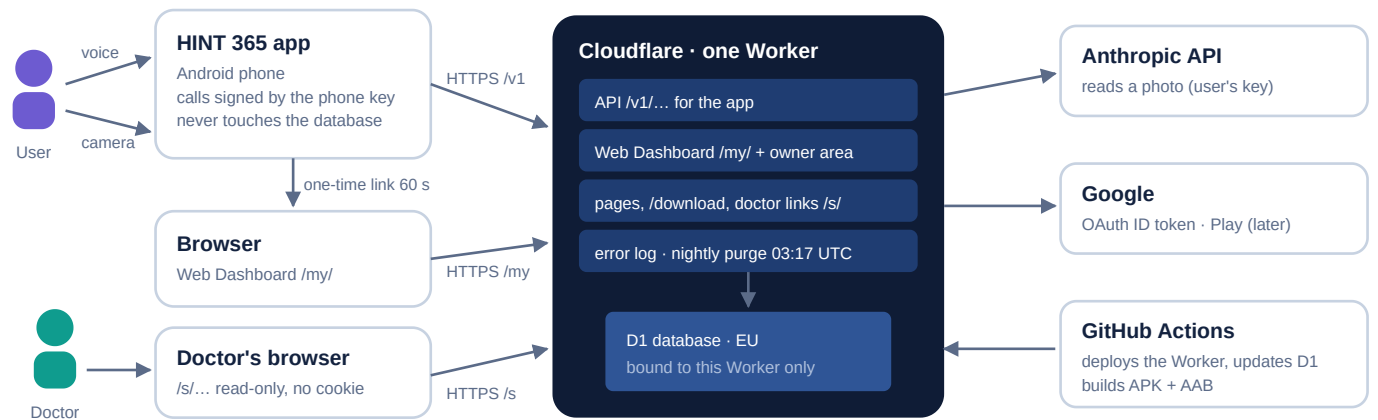
Hosting and runtime flow

Where every part runs, who talks to whom at run time, and how errors met by users are recorded.

Where it runs

Part	Runs on	Address	Operated by
Android app	The user's phone (APK; Google Play later)	installed from /download	the user
Web Dashboard (Blood pressure, Lab results; owner's area from the app)	Cloudflare Workers (static assets of the Worker) — not Vercel	personalhealthy-api.comevava76.workers.dev/my/	Cloudflare, owner's account
API for the app, public pages, doctor links	Cloudflare Workers, the same single Worker	.../v1/... · /privacy · /terms · /s/...	Cloudflare, owner's account
Database	Cloudflare D1 (SQLite), EU jurisdiction	no address: bound to the Worker only	Cloudflare, owner's account
Source, CI/CD, releases	GitHub: repository, Actions, Releases	comevava76-web/personalhealthy (private)	GitHub, owner's account

Runtime flow only the Worker touches the database



Error log continuous testing and improvement

- **Server**: failed signed calls (400–599, except 402, 404, 426) and every exception.
- **App**: crashes and failed PDF or Excel files; at most 20 a session.
- **Web**: script errors, at most 5 a page; never on a doctor's link.
- **Short**: one row per day, source, code, place, version, with a counter; no free-text messages, so no reading value; 90 days.

Who uses it

- **Owner**: Admin tab → total errors (90 days); the details reach the developer through the daily issue.
- **Developer**: every morning a scheduled routine reads the report of the log and fixes (page 5); in working sessions it is also read after every release.
- **Table**: `error_log` in D1, written by `worker/src/errors.ts`; app side `ErrorReport` in `Core.kt`; web side in `app.js`.

Security docs/security/

- **Each PR**: 168 security and functional checks; the app must compile.
- **Nightly**: live probe; every library (full tree) on OSV.dev; Semgrep; gitleaks → Admin → Security, with **Fix** (Claude Code).
- **Deadlines**: critical 48 h, high 7 days, moderate 30 days. Dependabot PRs on Mondays.
- **Cost**: 0 \$ extra (GitHub free plan, owner's Claude plan, OSV.dev public).

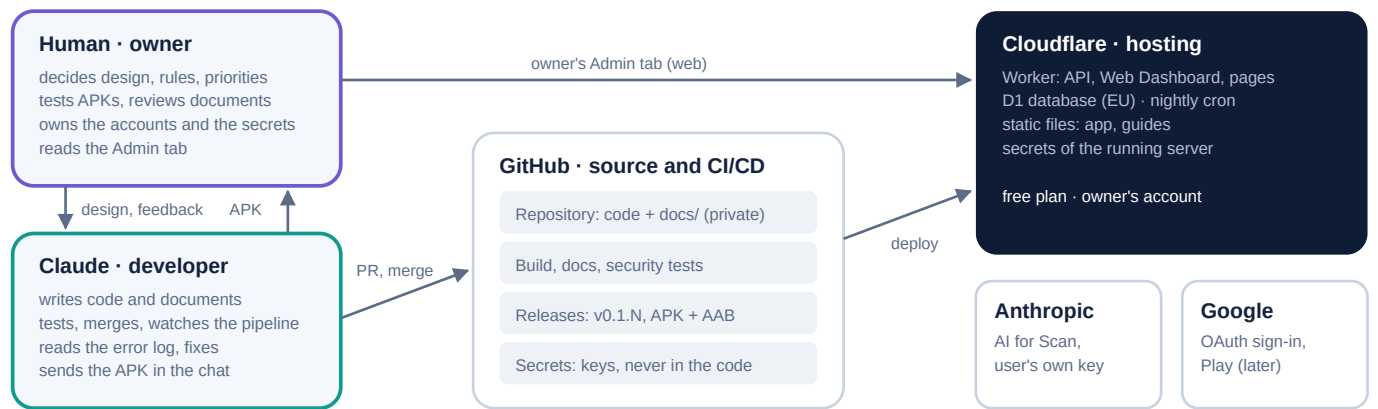
Data protection GDPR · Swiss FADP

- **Health data**, pseudonymous (not anonymous): the GDPR and the Swiss FADP apply. Basis: explicit consent (Art. 9(2)(a)) at sign-in and in the terms (v15, section "Data protection").
- **Roles**: owner = controller; Cloudflare = processor; Anthropic and Google in the US under their transfer safeguards.
- **Rights**: access, correction, deletion (in the app), a copy, restriction, objection; answer within one month.
- Gaps still open and the record of processing: `docs/compliance/gdpr.md`.

Roles and delivery

Who does what — the architect, the developer, the repository and the hosting — and how a change goes from the chat to the phone.

Roles people and platforms



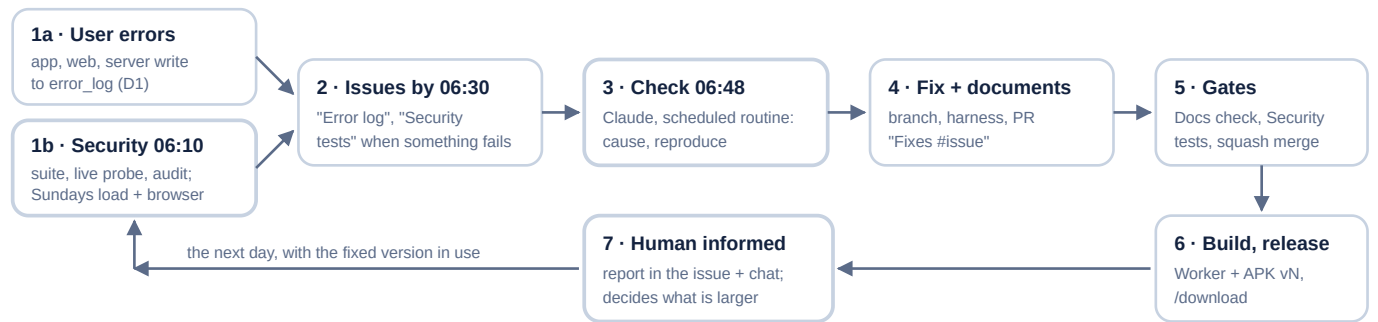
Responsibilities

Activity	Human · architect	Claude · developer	GitHub	Cloudflare
Design, rules, priorities	decides	proposes, asks when unclear	—	—
Code and documents (docs/)	reads	writes, same commit	stores	—
Tests before merge	—	runs	Docs check, Security tests	—
Merge, build, release	delegated	merges, watches	builds, releases	—
Hosting, database, cron	owns the account	—	deploys	runs
Keys and secrets	owns	never sees them	stores	stores
Trying the app on a phone	tries every APK	sends it	—	serves /download
Errors met by users	sees them in Admin	analyses, fixes	—	stores the log

Delivery, from the chat to the phone

- Decide** — Human describes the change in the chat; unclear points are asked, not guessed.
- Build and test** — Claude on `claude/...`: code and documents in one commit; harness, pages in Chromium, documents rendered.
- Merge** — pull request, *Docs check* and *Security tests* green, squash merge into `main`.
- Release** — local tests → privately signed APK/AAB → Worker + same-revision APK promotion → release record. No missing-key fallback. D1 tables, Worker, APK/AAB `v0.1.N`, `/download`; Claude checks it and sends the APK.
- Try** — Human tries the APK; feedback starts the next round. Rollback: revert the pull request.

Continuous improvement loop proactive: every day, without being asked



Security tests, vulnerability scan, Dependabot and who pays for the loop: page 4. Larger fixes wait for the human.

Application flows and permissions

Every flow of the application, step by step, and who is allowed to do what.

Application flows

#	Flow	Who	Steps	Data
1	Install, sign in	user	/download → install → Sign in with Google (OAuth, ID token checked by the Worker) → phone key registered	persons (fingerprint only)
2	Accept the terms	user	shown at first install, after every update and when the text changes → accept or the app closes	acceptances
3	Record by voice	user	Record → say SYS, DIA, PUL → check → Save reading → /v1/bp/voice	measurements
4	Turn on AI	user	Anthropic account → credit → key → paste → Worker tests it, stores it encrypted	person_keys
5	Scan (AI)	user with AI on	Scan → photo → Worker → Anthropic → values → check → Save → /v1/bp/confirm ; photo discarded	scans, measurements, ledger
6	See the report	user	Dashboard icon → Web Dashboard, Blood pressure tab: 7 days, one mean per day, the eight tiles of the app, morning/evening balance, extremes	read only
7	Share the report — app	user	Blood pressure tab, bottom → Send PDF or Excel → Android share sheet (WhatsApp, email, files...). The file goes straight from the phone to the app chosen; the server is not involved	none on the server
8	Share the report — web	user	Dashboard icon → Web Dashboard → cookie consent → PDF download (same A4) or Send to the doctor : Email or WhatsApp only; the PDF and a read-only link (7 days) go together, with a ready message in the phone's language; withdrawable	web_sessions, web_shares
9	Doctor's view	anyone with the link	open /s/... → charts and readings of that period, PDF; nothing else	read only
10	Delete, sign out	user	Admin → delete a reading, all, or the account; Sign out ends web sessions too	deleted at once
11	Owner's Admin tab	owner	App → Owner icon (shield, owner only) → web owner's area, not a tab of the dashboard: totals, D1 size, version switch-off; Observability: vulnerabilities, EU/CH compliance, problems and fixes, import outcomes	counts only
12	Import a lab report	user	Lab results → PDF or photo (own reports only, terms v18) → a progress bar: Processing → Scanning → Uploading → outcome, then it closes; the app keeps an upload history by day (saved reports from the server, uploads that saved nothing on the phone, outcome codes only); in the background, all or nothing; same file or same test and day never twice; web table: one column per date, ↑↓ orange outside the printed reference, delete a date	measurements, lab_files
13	Automatic	system	nightly: readings > 365 days, lab results never (only the user deletes them), expired links and sessions, errors > 90 days deleted; every error logged	purge, error_log

Who can do what

Action	User · app	User · web	Doctor · link	Owner	Developer
Record, scan, delete own readings	✓	—	—	own only	—
See own charts and report, export PDF/Excel	✓	✓ (PDF)	the shared period	own only	—
Create or withdraw a doctor link	—	✓	—	own only	—
See another person's readings or report	—	—	—	never	never
See usage totals (never per account)	—	—	—	✓ Admin tab	via the owner's connector, for checks
Read the error log	—	—	—	✓ Admin tab	✓ to fix
Switch app versions off	—	—	—	✓ Admin, Actions	—
Change code, docs, deploy	—	—	—	decides	✓ through pull requests
See keys and secrets	own AI key	—	—	✓ owns them	never

Enforced by the server: signed app calls, web session cookie, owner account, read-only expiring doctor links.